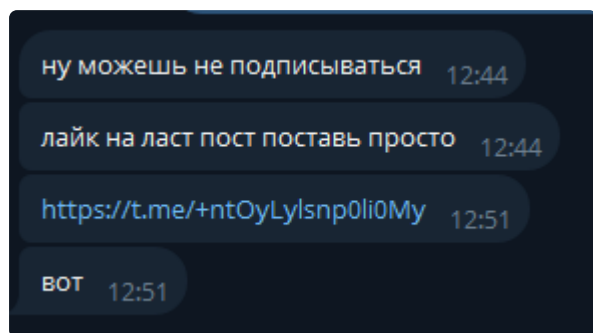


Кейс Social Engineering & Phishing Analysis

1. Введение / Сводка инцидента (Executive Summary)

- **Тема:** Анализ фишинговой атаки, направленной на компрометацию учетных данных единого портала «Госуслуги».
- **Объект исследования:** Аккаунт в Telegram с отображаемым именем «Катюша» (@kkkatry).
- **Суть инцидента:** Использование методов социальной инженерии (маскировка под профиль привлекательной девушки в дейтинг-сервисе Леонардо Дайвинчик). Злоумышленник переводит общение в мессенджер Telegram, где под предлогом подписки на свой приватный Telegram-канал пытается заставить жертву перейти по фишинговой ссылке:



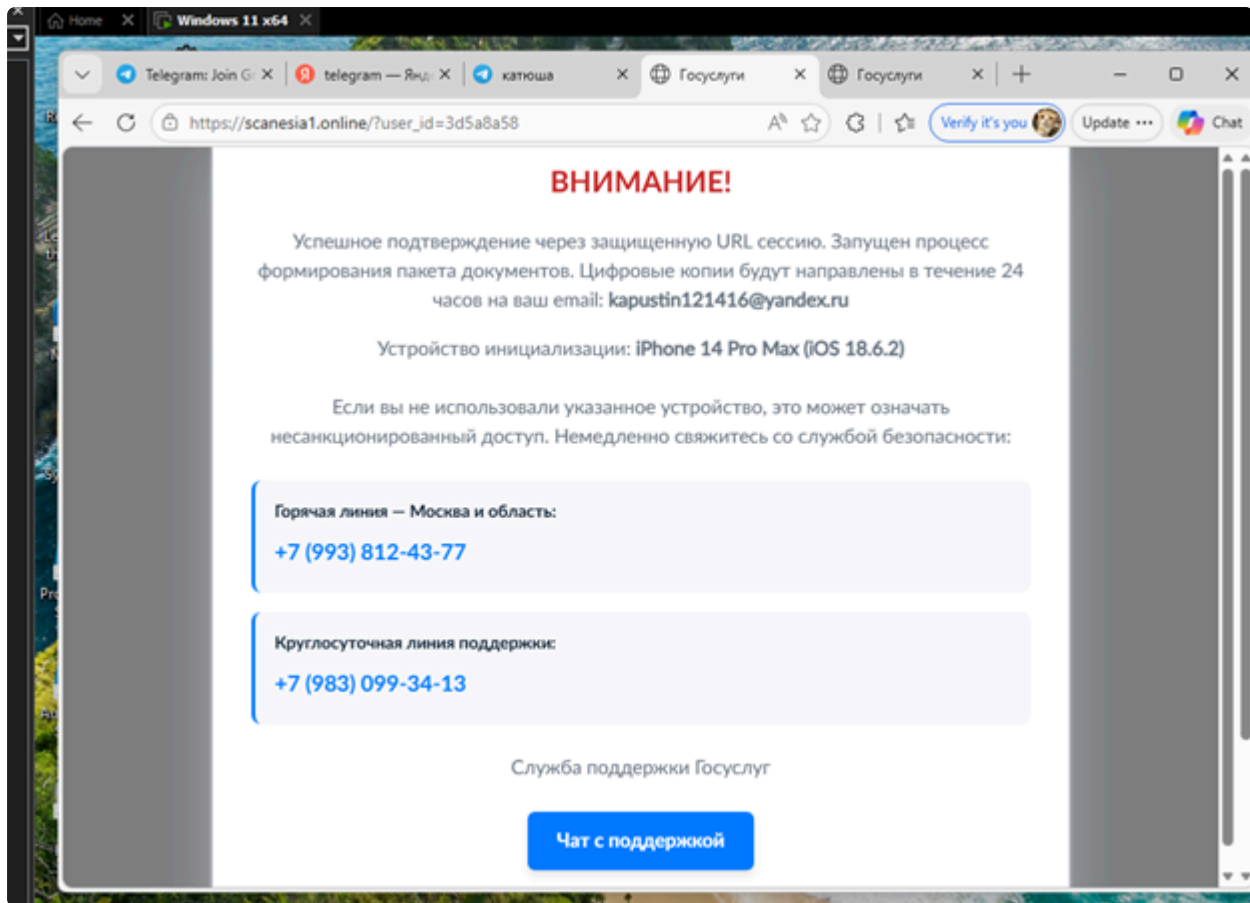
2. Технический анализ и Вектор атаки (Technical Analysis)

- **Этап 1: Социальная инженерия.** Злоумышленник вошел в доверие, предложив совершить простое действие («поставить лайк на последний пост») и предоставил гиперссылку, визуально неотличимую от стандартной инвайтинг-ссылки Telegram:

<https://t.me/+ntOyLyIsnp0li0My>.

- **Этап 2: Скрытый редирект.** При детальном анализе было установлено, что текстовое отображение ссылки маскирует реальный целевой URL. Переход по ссылке инициировал редирект на внешний фишинговый домен:
https://scanesia1.online/?user_id=3d5a8a58
- **Этап 3: Анализ фишинг-панели.** С целью безопасности исследование ресурса проводилось в изолированной виртуальной среде (Sandbox/VMware). Сайт имитирует интерфейс портала «Госуслуги». Пользователю демонстрируется ложное критическое уведомление о несанкционированном доступе с устройства

iPhone 14 Pro Max (iOS 18.6.2) и успешной отправке его документов на сторонний email kapustin121416@yandex.ru.



- **Цель злоумышленников:** Вызвать панику у жертвы из за неожиданности, вынудить её обратиться в чат с поддержкой где уже нужно ввести данные человека:

Поддержка портала Госуслуги

Заполните форму, и мы подключим свободного оператора.

ФИО

Дата рождения

ДД.ММ.ГГГГ

Номер телефона

Проблема

Вы сказали мошенникам код подтверждения из смс от Госуслуг?

ДА

НЕТ

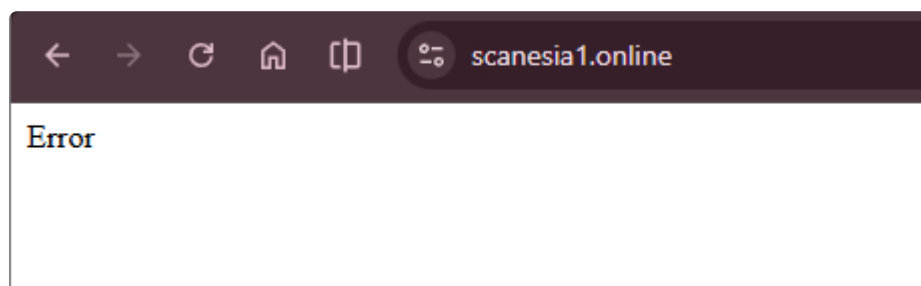
Можете войти в личный кабинет на Госуслугах?

ДА

НЕТ

3.Проверка номеров и почты на зацепки

При попытке перехода по корневому домену `scanesia1.online` сервер возвращает ошибку Generic Error. Это свидетельствует о том, что на веб-сервере **настроена фильтрация входящих запросов**, либо корень сайта пуст. Доступ к фишинговому контенту возможен исключительно при наличии валидного GET-параметра (в данном случае `?user_id=3d5a8a58`). Это стандартная практика сокрытия фишинговых панелей от автоматизированных краулеров и ИБ-аналитиков

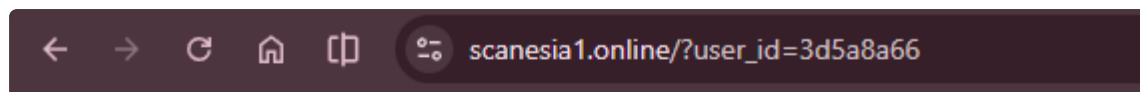


Вторым подтверждением активности фишинговой кампании является корректное отображение поддельного интерфейса портала "Госуслуги" при обращении по полной ссылке с UID

Если разберем данную ссылку

https://scania1.online/?user_id=3d5a8a58

Можно понять что работает сервер через определенный user_id.



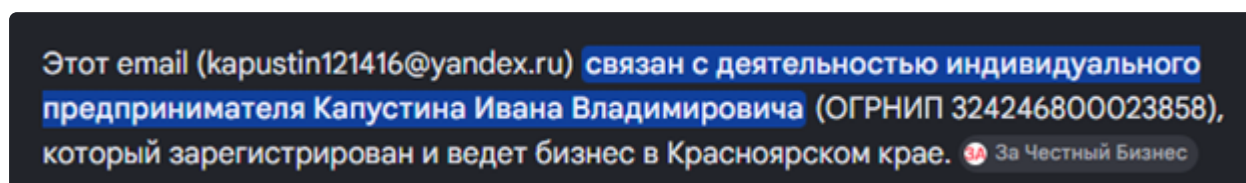
Ошибка: Пользователь не найден.

Попытка ручного перебора (брутфорса) GET-параметра `user_id` (например, `?user_id=3d5a8a66`) привела к ошибке "Пользователь не найден". Это подтверждает, что фишинговый скрипт работает по модели таргетированных сессий: под каждую потенциальную жертву генерируется уникальный уникальный идентификатор (UID), что усложняет массовый анализ кампании

Далее вспомним нашу почту : `kapustin121416@yandex.ru`

Я начал массово проверять на разных ресурсах.

Как итог почта оказалась:



Используемый злоумышленниками email `kapustin121416@yandex.ru` привязан к публичным данным ИП Капустина И.В. С высокой долей вероятности данные легитимного предпринимателя были использованы мошенниками в качестве **легенды (маскировки)** либо взяты из открытых баз данных для регистрации компрометирующего почтового ящика.

Можно заканчивать с почтой, а номера оказались виртуально покупными от газпрома.

Как итог выйти на человека доступными способами невозможно(если не включать доксинг по тг)

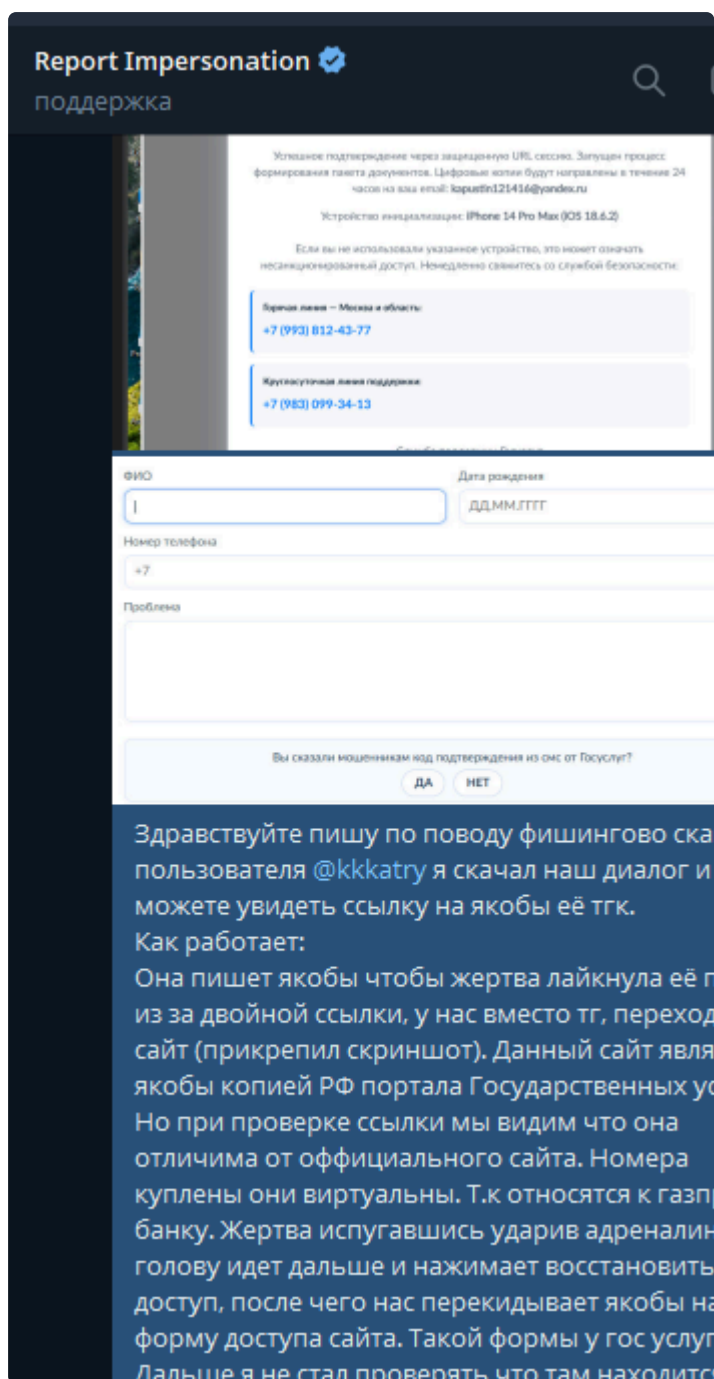
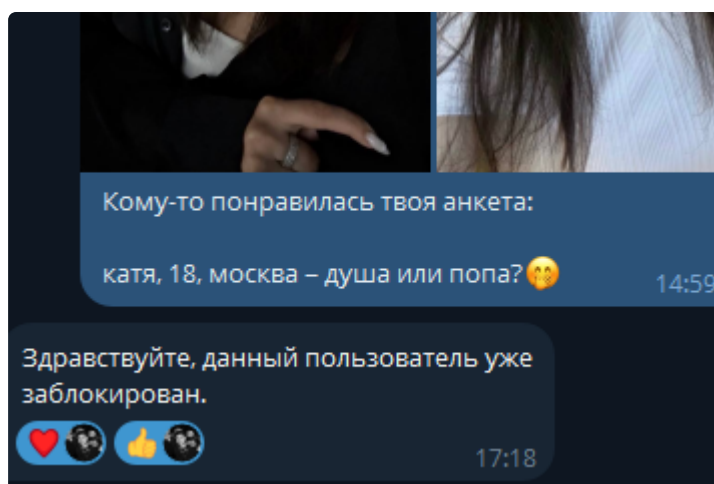
3. Индикаторы компрометации (IOCs)

Тип	Значение	Итог
Домен фишинга:	scanesia1.online	Активен, доступ ограничен фильтрацией веб-сервера
Целевой фишинг-URL:	https://scania1.online/?user_id=3d5a8a58	работает только с этим айди

Тип	Значение	Итог
Почтовый ящик злоумышленников (почта для соц инженерии):	kapustin121416@yandex.ru	Данные легитимного ИП(Капустина) использованы в качестве маскировки
Номера телефонов мошенников:	+79938124377, +79830993413	виртуальные номера связанные с дочерней компанией газпрома <i>Оператор: "Новые Мобильные Коммуникации" ООО</i>

4. Принятые меры реагирования (Incident Response)

- Проведен первичный анализ инфраструктуры.
- Внутренние папки и админ-панель скрыты (доступ ограничен настройками веб-сервера, выдает 403/404).
- Подготовлена и отправлена жалоба на все ресурсы как ДВ где мошенник обитает так и самому ТГ.



На чем хотел сыграть мошенник(мысли): я считаю он хотел сыграть на человеческом адреналине. Увидев такое сообщение многих начинает трясти и они теряют голову, начиная судорожно связываться с поддержкой.

В ИБ это называется **«Атака на основе создания дефицита времени и страха» (Urgency & Fear exploit)**. Человек пугается, что его доки улетели Капустину, и начинает звонить по фейковым номерам «Газпромбанка», где подставной «оператор Госуслуг» уже разводит его на СМС-код.

Как не попасться: в первую очередь по ссылкам переходите только через браузер, ведь там как правило(так я и понял про ссылку внутри) показывается настоящая ссылка куда вас хотят перебросить.